

DEVOPS E ARQUITETURA CLOUD

FASE 3 | AULA 06 -

RISCO DAS DEPENDÊNCIAS: SUPPLY CHAIN E SBOM

SUMÁRIO

O QUE VEM POR AÍ?	3
HANDS ON	4
SAIBA MAIS.....	5
MERCADO, CASES E TENDÊNCIAS	9
O QUE VOCÊ VIU NESTA AULA?	10
REFERÊNCIAS.....	11

O QUE VEM POR AÍ?

O ritmo acelerado dos pipelines de CI/CD gera um volume crescente de dados de segurança fragmentados, provenientes de múltiplos *scanners* (SAST, DAST, IaC). O verdadeiro desafio não é encontrar vulnerabilidades, mas sim **gerenciá-las e priorizá-las** de forma eficiente para evitar a "fadiga de alertas" nos times de engenharia.

Nesta aula, vamos focar na orquestração e disciplina. Utilizaremos o OWASP DefectDojo para centralizar e transformar esses relatórios em um ecossistema acionável, aplicando inteligência de risco preditiva (EPSS) para direcionar os esforços de remediação onde o risco real de negócio é maior.

HANDS ON

A jornada prática iniciará com a fundação: a primeira videoaula focará na inicialização do DefectDojo via Docker Compose. Você se familiarizará rapidamente com a interface, entendendo a hierarquia essencial de *Products* e *Engagements*. Assimilar essa arquitetura de escopo é vital, pois ela estrutura como a deduplicação de dados de segurança é aplicada e gerenciada.

Em seguida, o foco mudará para a automação essencial de pipelines DevSecOps. O segundo vídeo demonstrará, de forma prática, a criação de scripts que utilizam a API V2 do DefectDojo. Serão ingeridos relatórios de *scanners* como Trivy, ZAP e Horusec diretamente durante o *build* no CI/CD. Este passo vai garantir que o *feedback loop* de segurança seja imediato e sem intervenção manual, estabelecendo a segurança como um passo inercial.

Finalmente, a terceira videoaula abordará a tomada de decisão estratégica. Você praticará a interpretação do *Dashboard* de vulnerabilidades. A priorização será baseada na Gestão de Risco, combinando a severidade técnica (CVSS) com a probabilidade de exploração. O objetivo será definir SLAs de correção que alinhem a remediação técnica com o risco de negócio, transformando o DefectDojo em uma ferramenta de inteligência executiva.

SAIBA MAIS

DefectDojo como o Orquestrador Central de Vulnerability Management (VM)

O DefectDojo é uma plataforma *open-source* do projeto OWASP especificamente projetada para centralizar e organizar a gestão do ciclo de vida das vulnerabilidades. Ele atua como uma camada de agregação de dados (*data aggregation layer*), resolvendo a crise de dados de segurança gerada pelo uso de múltiplos *scanners* (SAST, DAST, IaC, etc.). Ao centralizar as informações, o DefectDojo otimiza o *Vulnerability Lifecycle*, facilitando a detecção, a priorização, a remediação e o monitoramento contínuo dos riscos de segurança.

A modelagem da arquitetura de entidades no DefectDojo, conhecida como Hierarquia de Produtos (*Product Hierarchy*), é crucial para a gestão de acesso e escopo. A hierarquia é composta por cinco classes principais de dados: **Product Types > Products > Engagements > Tests > Findings**. Um *Product* representa uma aplicação ou sistema específico, sendo a fronteira onde a **Deduplicação de Findings** e a aplicação das **SLA Configurations** (Acordos de Nível de Serviço) são definidas. Uma modelagem granular de *Products* é essencial para garantir que a triagem, o rastreamento e o SLA sejam contextualmente corretos.

Automação da Ingestão de Dados via API V2 em Pipelines CI/CD

A integração do DefectDojo em ambientes de alta frequência exige que a plataforma seja *API-First*. A autenticação é realizada via **Token Header** (Authorization: Token <api_key>), e essa chave deve ser gerenciada como um segredo de alta sensibilidade no pipeline de CI/CD.

Para fluxos de trabalho contínuos, o *endpoint /reimport* é o mais robusto. Ele automaticamente busca o teste mais recente e, se um *Finding* corrigido não estiver presente no novo relatório, o sistema marca como **Mitigado** (função de *autoclose*). Essa funcionalidade é vital para manter a higiene dos dados e garantir que as métricas de remediação sejam precisas. O uso da *flag* `auto_create_context: True` simplifica a integração de novos repositórios ao fluxo DevSecOps, permitindo que o *Product* ou *Engagement* seja provisionado dinamicamente.

Gestão de Risco Preditivo (RBVM) com CVSS e EPSS

A gestão de risco em TI deve distinguir claramente entre **severidade técnica** e **risco real de negócio**. O Common Vulnerability Scoring System (CVSS) mede a **severidade técnica** (o quão fácil é explorar a falha e qual seria seu impacto máximo).

A versão 4.0 do CVSS aprimora o sistema ao formalizar o uso de métricas de **Threat (T)** e **Environmental (E)**, resultando na pontuação **CVSS-BTE**. Ao incorporar a inteligência de ameaça e o contexto de negócio, a pontuação CVSS-BTE se aproxima do **Risco** real, orientando a priorização de forma mais inteligente do que o score Base isolado.

Pontuação CVSS	Severidade Qualitativa
0.0	None (Nenhum)
0.1 – 3.9	Low (Baixo)
4.0 – 6.9	Medium (Médio)
7.0 – 8.9	High (Alto)
9.0 – 10.0	Critical (Crítico)

Tabela 1 – Escala Qualitativa de Severidade (CVSS v4.0)
Fonte: elaborado pelo autor (2025)

O **Risk-Based Vulnerability Management (RBVM)** utiliza o Exploit Prediction Scoring System (EPSS) para otimizar essa priorização. O EPSS utiliza modelos de *Machine Learning* para estimar a **probabilidade** (0-100%) de que uma vulnerabilidade seja ativamente explorada *in the wild* nos próximos 30 dias. Este foco preditivo é essencial, pois apenas 2% a 7% das vulnerabilidades são exploradas de fato. O DefectDojo integra automaticamente as pontuações EPSS, permitindo que **você** se concentre nos **True Positives** (alto impacto CVSS **E** alta probabilidade EPSS), maximizando a redução de risco pelo menor custo de remediação.

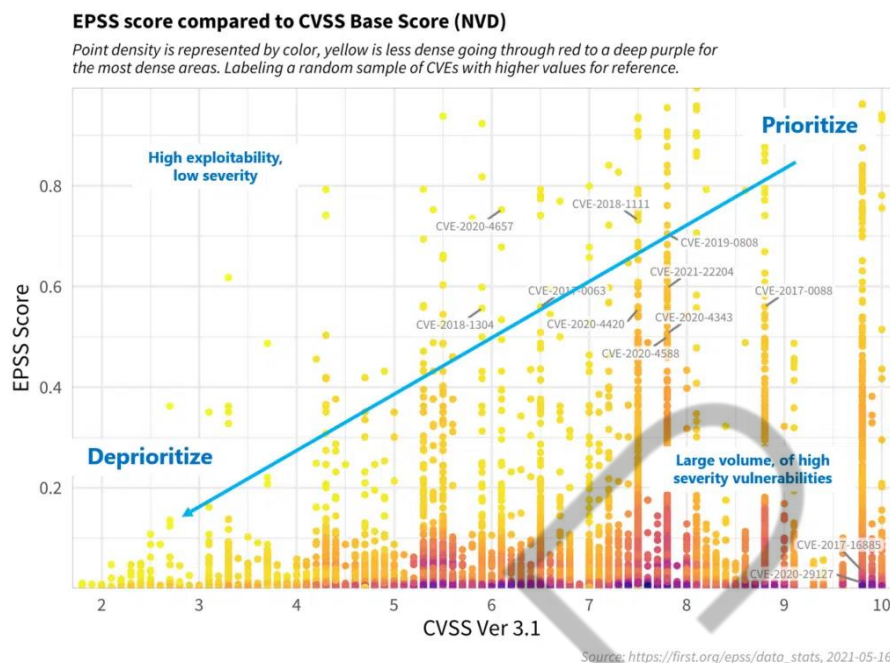


Figura 1 – Score CVSS e Score EPSS
Fonte: [Nopse](#) (2025)

Otimização do Workflow: Deduplicação e Gestão de Falsos Positivos

O ruído gerado por *Findings* duplicados é um dos principais sabotadores da eficiência do DevSecOps. A deduplicação é um recurso central no DefectDojo, limitando a quantidade de *Findings* rastreados a apenas uma instância de vulnerabilidade por *Product*.

O DefectDojo suporta diferentes algoritmos, selecionáveis por tipo de *parser*:

- **Unique ID From Tool:** utiliza o identificador único fornecido pelo *scanner* (preferível).
- **Hash Code:** calcula um valor *hash* com base em campos configuráveis (ex: *file_path*, *line*).

A persistência de status constrói confiança cultural: se um *Finding* for manualmente marcado como **False Positive**, **Out Of Scope** ou **Risk Accepted**, ele reterá esse status em reimports subsequentes. No entanto, se um *Finding* que foi marcado como **Mitigado** for re-reportado em um *scan*, o DefectDojo o **reativa** automaticamente, sinalizando uma regressão de segurança que requer atenção imediata.

Sincronização e Rastreamento de MTTR via Webhooks

Uma plataforma de VM eficaz fecha o ciclo de vida da vulnerabilidade, garantindo que a correção no código se reflita no status da plataforma em tempo real. Isso é obtido pela integração com sistemas de rastreamento de tickets (Jira/ServiceNow), guiada por critérios de **RBVM** e SLAs de correção.

O estabelecimento de SLAs (ex: 7 dias para risco crítico, 30 dias para risco alto) é crucial para a governança e para o cálculo do **Mean Time to Remediation (MTTR)**, uma métrica executiva de higiene cibernética.

Risco (Baseado em CVSS/EPSS)	SLA de Resolução
Crítico (EPSS > 0.5)	7 Dias
Alto (EPSS < 0.5)	30 Dias
Médio	90 Dias

Tabela 2 – Risco (Baseado em CVSS/EPSS)
Fonte: elaborado pelo autor (2025)

A sincronização bidirecional, garantida pelos Webhooks, elimina a latência humana. O DefectDojo envia o *Finding* para o Jira como um *Issue*. Quando o desenvolvedor resolve o *Issue* no Jira, um Webhook configurado escuta o evento 'Issue Updated' e envia uma requisição POST de volta ao DefectDojo, que interpreta o *payload* e marca o *Finding* como Mitigado. Essa automação garante a altíssima integridade dos dados de MTTR.

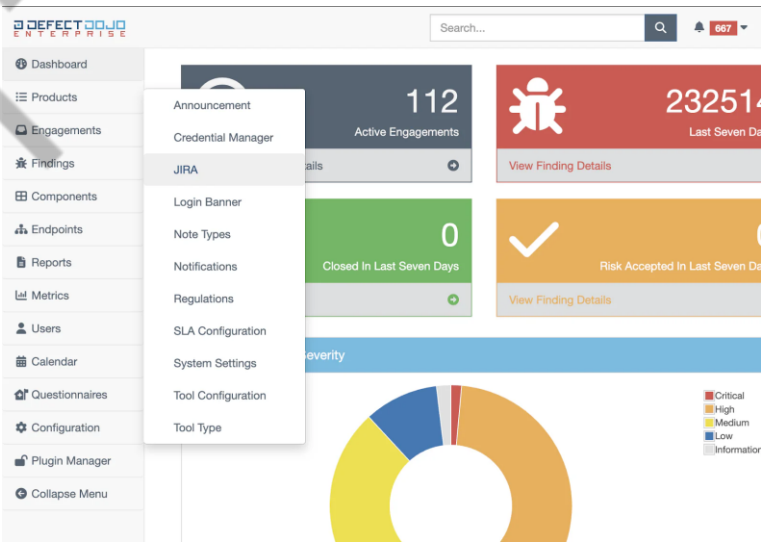


Figura 2 – DefectDojo Findings
Fonte: [Defectdojo](https://defectdojo.com) (2025)

MERCADO, CASES E TENDÊNCIAS

A orquestração e a gestão centralizada de vulnerabilidades são um movimento estratégico no mercado de DevSecOps, impulsionado pela complexidade das arquiteturas *cloud-native* e pelos requisitos regulatórios. Empresas de grande porte, como instituições financeiras globais e agências governamentais, adotam plataformas de *Vulnerability Management* (VM) em larga escala como um imperativo para formalizar e escalar suas *software factories*, garantindo consistência e rastreabilidade.

O mercado testemunha um afastamento da correção por volume de CVSS, priorizando métricas de higiene como o **Mean Time to Patch (MTTP)** em vulnerabilidades que representam uma ameaça explorável. Essa demanda impulsiona a adoção de scores preditivos como o EPSS. O uso de EPSS, que se baseia em *Machine Learning* para prever a probabilidade de exploração, garante que os recursos de remediação sejam alocados de forma otimizada para onde o risco de comprometimento é maior. Isso transforma a triagem de vulnerabilidades de uma abordagem reativa em uma **ciência preditiva**.

A tendência que moldará o futuro da gestão centralizada é a convergência com a Inteligência Artificial para Operações de TI (AIOps). Plataformas de VM, como o DefectDojo, posicionam-se como a fonte de dados estruturados e de alta integridade que alimenta futuras ferramentas de IA. A API robusta e os dados unificados de *Findings* e métricas de risco são essenciais para construir capacidades de autoatendimento e análise preditiva. O DefectDojo, ao abstrair a complexidade do *toolchain* de segurança, torna-se um componente vital na construção de **Internal Developer Platforms (IDPs)**, que buscam elevar a produtividade do desenvolvedor ao mesmo tempo que mantêm a resiliência do sistema.

O QUE VOCÊ VIU NESTA AULA?

Nesta aula, a orquestração de vulnerabilidades foi abordada como um processo estratégico e fundamental para a maturidade do DevSecOps. Você compreendeu como o OWASP DefectDojo atua como a plataforma central para agregar, deduplicar e gerenciar o ciclo de vida da vulnerabilidade. Explorou-se a importância da Hierarquia de Produtos para o escopo correto da gestão de risco e a integração essencial via API V2 (/reimport) para a automação do *feedback loop* no CI/CD.

O estudo aprofundado das métricas demonstrou a necessidade de transcender a severidade técnica (CVSS v4.0) para adotar o risco preditivo, utilizando o **Exploit Prediction Scoring System (EPSS)**. Finalmente, o ciclo de remediação foi fechado com a análise da gestão de Falsos Positivos e a sincronização bidirecional via Webhooks com sistemas de tickets (Jira/ServiceNow), um passo vital para otimizar o Mean Time to Remediation (MTTR) e garantir a integridade das métricas de higiene cibernética.

REFERÊNCIAS

FIRST.org. **Common Vulnerability Scoring System (CVSS) Version 4.0 Specification Document**. 2024. Disponível em: <https://www.first.org/cvss/v4-0/specification-document> . Acesso em: 01 dez. 2025.

FIRST.org. **Exploit Prediction Scoring System (EPSS)**. 2025. Disponível em: <https://www.first.org/epss/>. Acesso em: 01 dez. 2025.

NIST. **Common Vulnerability Scoring System (CVSS)**. 2024. Disponível em: <https://nvd.nist.gov/vuln-metrics/cvss>. Acesso em: 01 dez. 2025.

OWASP. **DefectDojo Documentation**. 2025. Disponível em: <https://docs.defectdojo.com/>. Acesso em: 01 dez. 2025.

PALAVRAS-CHAVE

DefectDojo. DevSecOps. Vulnerability Management (VM). CVSS v4.0. EPSS (Exploit Prediction Scoring System). Risk-Based Vulnerability Management (RBVM). Automação CI/CD. Webhooks. Deduplicação de Falhas. Jira. MTTR (Mean Time to Remediation).

EMANIP



POS TECH